

VaultKeepR Android v1.8.9 — Static Analysis Report

Tool: **MobSF** (Mobile Security Framework, static analysis) · Artifact: VaultKeepR-v1.8.9-signed.apk (xyz.vaultkeepr.app) · Scan date: 27 September 2026

TRACKERS DETECTED: 0 / 432

MALICIOUS DOMAINS: 0

SECURITY SCORE (RAW): 55 / 100

POST-TRIAGE: 62 / 100

TOOL-GENERATED DATA

0 / 432
TRACKERS DETECTED

0
MALICIOUS DOMAINS

55 → 62
MOBSF SCORE RAW → POST-TRIAGE

124.1 MB
APK SIZE

Artifact identity

FIELD	VALUE
Package	xyz.vaultkeepr.app (version 1.8.9, versionCode 43)
SHA-256	8be4436e5a62b833371815c3aaf9c530d7308b7cdd3beb15ed750493066ced01
min SDK / target SDK	29 / 36
Signing certificate	CN=VaultKeepR, OU=Mobile, O=VaultKeepR, C=FR (maintainer release identity) · v2+v3 scheme
android:allowBackup	False — backup of vault data via adb/OS transfer is disabled

Manifest & permission posture (verified in the APK binary)

CHECK	RESULT
Privacy trackers (432-signature database)	0 detected
Malware domain check (Maltrail)	0 malicious domains
Sensitive permissions (microphone, fine/coarse location, external storage, media images)	Absent from the final merged manifest
CAMERA permission	Kept intentionally — QR-code scanning for 2FA enrolment
Biometric unlock (USE_BIOMETRIC)	Declared — Face ID/fingerprint gate for the vault, exercised by the E2E suite
android:allowBackup	false — verified in the merged manifest of this build

Findings triage

FINDING (TOOL OUTPUT)	ASSESSMENT	ACTION
android:allowBackup	Remediated in this build. The v1.8.8 analysis flagged allowBackup="true" — vault data was copyable via adb backup / OS device transfer.	Fixed at source (Expo config plugin forcing allowBackup="false" on <application>); verified absent from this build's manifest.

Remote WebView debugging enabled	False positive on release builds: the library call is gated by <code>if (ReactBuildConfig.DEBUG)</code> and dead code in release.	None — documented false positive (guard at <code>RNCWebViewManagerImpl.kt:91-93</code>).
55 "hardcoded secrets" strings	False positives on manual review: native crypto library symbol names (OpenSSL/BoringSSL/SLH-DSA tables), Android resource-string identifiers, and the Firebase public API key (public by design per Google's documentation).	None — documented false positives.
Exported components (main activity, deep-link receiver)	Launcher entry point and deep-link handler (<code>vaultkeeper://</code>) — required for app links and covered by the E2E suite.	None — documented.
Third-party logging / MD5 cache digests / raw SQL in bundled libraries	Library-internal code paths (React Native, Expo modules); app-side logging is routed through a redacting logger. MD5 use is limited to cache integrity, not security.	Documented — reviewed on each dependency upgrade.
APK size 124 MB	React Native runtime plus bundled native crypto libraries (Argon2, XChaCha20-Poly1305, SLH-DSA).	Under review for future slimming.

Suppression log (documented false positives)

Nine SAST rules whose findings were verified as false positives on manual review are suppressed in the tool (reversible; the suppression list is retained by the tool for this artifact's hash). Each rule is re-evaluated on dependency upgrades.

SUPPRESSED RULE	JUSTIFICATION (VERIFIED)
<code>android_webview_debug</code> (high)	Library call guarded by <code>if (ReactBuildConfig.DEBUG)</code> — dead code in release builds.
<code>android_hardcoded</code>	Native crypto symbol names (OpenSSL/BoringSSL/SLH-DSA tables), Android resource-string identifiers, Firebase public API key (public by design).
<code>android_md5</code>	MD5 used by third-party libraries for cache integrity only; vault cryptography uses Argon2id, XChaCha20-Poly1305, SHA-256/ECDSA/SLH-DSA.
<code>android_sql_raw_query</code>	AsyncStorage (React Native) parameterized internally; no user-crafted SQL in app code.
<code>android_temp_file</code>	Temporary files in bundled libraries (cropper, WebView download cache) — app-private storage, cleared by the OS.
<code>android_read_write_external</code>	Library code paths (WebView download module, clipboard file provider); the corresponding permissions are stripped from the merged manifest (verified in the AXML binary).
<code>android_logging</code>	Informational logging in bundled libraries; app-side logging routes through a redacting logger.
<code>android_clipboard_listen</code> / <code>android_clipboard_copy</code>	Clipboard access by the Expo clipboard module (user-initiated copy/paste) — no background listening.

Method & scope

Artifact scanned with **MobSF** (Mobile Security Framework, self-hosted Docker, image `opensecurity/mobile-security-framework-mobsf:latest`, pulled 2026-09-27): static analysis of the signed APK — manifest analysis, code analysis,

permission mapping against the merged manifest, tracker detection (432-signature database), malware domain check, and binary/secret-string review. MobSF's native PDF export endpoint failed on this build (upstream defect); this document is a regenerated summary of the tool's raw report — every number quoted verbatim from the tool output (raw score 55/100; 62/100 after the documented suppressions listed above), and manifest-level claims additionally verified against the APK binary itself (AXML string pool). It is **automated static analysis, not a manual code audit**, and complements the E2E and VirusTotal reports published in this repository. Play Store distribution is signed with the store-managed upload key; the tool artifact above reflects the maintainer release identity of the GitHub channel.

Reproducibility: APK SHA-256 `8be4436e5a62b833371815c3aaf9c530d7308b7cdd3beb15ed750493066ced01`, MobSF static scan of 2026-09-27, full raw report retained by the maintainer. Format follows the repository `audits/` convention. Questions: security@vaultkeepr.xyz.